

National University of Computer and Emerging Sciences

Information Assurance

Fall 2025 – Project

Project Overview

Implementation of Information Security Management System (ISMS) for Organization XYZ

Implementation of an ISO 27001-Compliant Information Security Management System (ISMS) for Organization XYZ (as per students' choice).

Background

Organization XYZ is committed to safeguarding its information assets against evolving threats in a digital landscape. To achieve this, the organization seeks to establish a robust Information Security Management System (ISMS) aligned with the ISO 27001 standard (including guidance from ISO 27002 for information security controls). This project addresses the need for systematic identification, assessment, and management of information security risks, ensuring compliance, confidentiality, integrity, and availability of critical data.

The ISMS will provide a framework for ongoing security governance, reducing vulnerabilities and enhancing resilience against cyber threats, data breaches, and operational disruptions. This initiative is driven by regulatory requirements, stakeholder expectations, and the organization's strategic goal to foster a culture of security awareness.

CLOs Covered

After completion of the project, the student shall be able to:

1. Apply security governance principles through understanding of security functions to strategy, goals, and objectives; organizational processes developing and implementing documented security policy, standards, procedures, and guidelines; threat modeling and risk management.
2. Understand and apply risk management concepts
3. To understand the business, legal, and technical knowledge needed to secure vital government and business assets.

Project Scope

The project will focus on the following core elements of ISMS implementation for Organization XYZ:

1. Definition of ISMS boundaries, including applicable processes, locations, and assets. (Required: ISMS Scope Document)
2. Comprehensive asset identification and valuation (Required: Asset Inventory Document).
3. Risk assessment covering threats, vulnerabilities, and impacts (Required: Asset Risk Assessment Document).
4. Selection and justification of controls from ISO 27001 Annex A (with ISO 27002 guidance) (Required: Risk Control Management Document).
5. Gap analysis to identify discrepancies between current practices and ISO 27001 requirements (Required: Gap Analysis Document).

6. Declaration justifying the inclusion or exclusion of each control from ISO 27001 Annex A (Required: SoA Document).
7. Development of key policies and documentation (Required Documents: Asset Management Policy, Clear Desk Policy, Network/Internet Usage and Security Policy, Log Management Policy).
8. Preparation of a presentation summarizing the project outcomes (Project Presentation).

The ISMS will encompass all information assets handled by XYZ, including digital data, physical documents, IT infrastructure, and personnel-related information.

Deliverables

The project will produce the following key documents and outputs, structured to meet ISO 27001 requirements:

1. **ISMS Scope Document:** A formal document outlining the boundaries, objectives, and context of the ISMS, including internal and external issues, interested parties, and interfaces.
2. **Asset Inventory:** A detailed register of all information assets, categorized by type (e.g., hardware, software, data, personnel), ownership, location, and value to the organization.
3. **Asset Risk Assessment Document:** An analysis identifying vulnerabilities, threats (e.g., cyber attacks, insider threats, natural disasters), likelihood, impact, and overall risk levels for each asset, using a qualitative or quantitative methodology.
4. **Risk Control Management Document:** A risk treatment plan specifying selected controls, mitigation strategies, residual risks, and responsibilities for implementation and monitoring.
5. **Gap Analysis Document:** A review comparing current security practices against ISO 27001 controls, highlighting gaps, recommendations, and prioritization for remediation.
6. **Statement of Applicability (SoA) Document:** A declaration justifying the inclusion or exclusion of each control from ISO 27001 Annex A, with rationale based on risk assessment and organizational needs.
7. **Security Policies:**
 - a. **Asset Management Policy:** Guidelines for identifying, classifying, handling, and disposing of assets.
 - b. **Clear Desk Policy:** Procedures to ensure sensitive information is secured when workspaces are unattended.
 - c. **Network/Internet Usage and Security Policy:** Rules for acceptable use of network resources, including internet access and remote connections.
 - d. **Log Management Policy:** Protocols for collecting, storing, reviewing, and retaining system logs to detect and respond to security incidents.
8. **Project Presentation:** A slide deck (e.g., in PowerPoint format) summarizing the project methodology, key findings, deliverables, and recommendations, suitable for executive review.

All deliverables will be formatted professionally, version-controlled, and stored in a secure repository.

Project Team:

This project can be done in a group of students 4 or less.